

KDLS 24 UG – Prüfungsvorbereitung AP1

Datenschutz (DSGVO)

1. Grundlagen des Datenschutzes

Datenschutz schützt personenbezogene Daten und die Rechte der betroffenen Personen. Zentrale Rechtsgrundlage ist die Datenschutz-Grundverordnung (DSGVO), die für alle Unternehmen gilt.

2. Grundsätze der Verarbeitung (Art. 5 DSGVO)

2.1 Rechtmäßigkeit, Treu und Glauben, Transparenz

- Datenverarbeitung nur mit gültiger Rechtsgrundlage (z. B. Einwilligung, Vertrag, gesetzliche Pflicht).
- Betroffene müssen nachvollziehen können, was mit ihren Daten geschieht.

2.2 Zweckbindung

- Daten werden für festgelegte, eindeutige und legitime Zwecke erhoben.
- Keine Weiterverarbeitung für andere Zwecke ohne neue Rechtsgrundlage.

2.3 Datenminimierung

- Nur die Daten erheben, die für den Zweck wirklich erforderlich sind.

2.4 Richtigkeit

- Daten müssen sachlich richtig und aktuell sein.
- Unrichtige Daten sind zu berichtigen oder zu löschen.

2.5 Speicherbegrenzung

- Daten nur so lange speichern, wie es für den Zweck notwendig ist.
- Löschkonzepte und Aufbewahrungsfristen sind festzulegen.

2.6 Integrität und Vertraulichkeit

- Schutz vor unbefugter oder unrechtmäßiger Verarbeitung.

- Schutz vor Verlust, Zerstörung oder Schädigung durch technische und organisatorische Maßnahmen.

2.7 Rechenschaftspflicht

- Der Verantwortliche muss die Einhaltung aller Grundsätze nachweisen können (Dokumentation, Konzepte).

3. Rechtsgrundlagen der Verarbeitung (Art. 6 DSGVO)

- Einwilligung der betroffenen Person.
- Vertragserfüllung (z. B. Liefervertrag, Dienstleistungsvertrag).
- Erfüllung rechtlicher Verpflichtungen (z. B. steuerliche Aufbewahrung).
- Wahrung berechtigter Interessen (z. B. IT-Sicherheit, Betrugsprävention), sofern keine überwiegenden Interessen der Betroffenen entgegenstehen.

4. Betroffenenrechte

- Auskunft über gespeicherte personenbezogene Daten.
- Berichtigung unrichtiger Daten.
- Löschung („Recht auf Vergessenwerden“) unter bestimmten Voraussetzungen.
- Einschränkung der Verarbeitung.
- Datenübertragbarkeit.
- Widerspruch gegen bestimmte Verarbeitungen.
- Widerruf einer Einwilligung.

5. Rollen im Datenschutz

- **Verantwortlicher:** entscheidet über Zwecke und Mittel der Verarbeitung.
- **Auftragsverarbeiter:** verarbeitet Daten im Auftrag des Verantwortlichen.
- **Datenschutzbeauftragter:** überwacht die Einhaltung der DSGVO, berät und schult.

6. Datenschutzverletzungen

- Verlust oder Diebstahl von Datenträgern.
- Unbefugter Zugriff auf personenbezogene Daten.
- Fehlversand von Daten an falsche Empfänger.
- Malwarebefall mit Datenabfluss.

Schwere Verletzungen sind in der Regel innerhalb von 72 Stunden der zuständigen Aufsichtsbehörde zu melden.

Begriffsbestimmungen: Datenschutzbeauftragter & Informationssicherheitsbeauftragter

Datenschutzbeauftragter (DSB)

Der Datenschutzbeauftragte überwacht die Einhaltung der DSGVO und des BDSG im Unternehmen. Er berät die Geschäftsleitung, schult Mitarbeitende und ist Ansprechpartner für Betroffene sowie für die Aufsichtsbehörde.

Aufgaben des Datenschutzbeauftragten

- Überwachung der Einhaltung von DSGVO und BDSG
- Beratung der Verantwortlichen und Mitarbeitenden
- Durchführung von Schulungen und Sensibilisierung
- Prüfung und Bewertung von TOMs
- Begleitung von Datenschutz-Folgenabschätzungen (DSFA)
- Anlaufstelle für Betroffene (Auskunft, Löschung, Beschwerden)
- Kontaktstelle für die Aufsichtsbehörde

Verpflichtende Bestellung eines Datenschutzbeauftragten

Ein DSB muss bestellt werden, wenn:

- mindestens **20 Personen** regelmäßig personenbezogene Daten verarbeiten (§ 38 BDSG)
- besonders sensible Daten nach Art. 9 DSGVO verarbeitet werden
- die Kerntätigkeit die umfangreiche Überwachung von Personen ist
- die Kerntätigkeit die umfangreiche Verarbeitung personenbezogener Daten ist

Informationssicherheitsbeauftragter (ISB)

Der Informationssicherheitsbeauftragte verantwortet die Informationssicherheit im Unternehmen. Grundlage sind BSI-Standards (200-1, 200-2, 200-3) sowie interne Sicherheitsrichtlinien.

Aufgaben des Informationssicherheitsbeauftragten

- Erstellung und Pflege des Informationssicherheitskonzepts
- Durchführung von Risikoanalysen
- Definition und Kontrolle technischer und organisatorischer Maßnahmen (TOMs)
- Koordination von Sicherheitsvorfällen (Incident Response)
- Schulung der Mitarbeitenden zur IT-Sicherheit
- Überwachung der Einhaltung von Sicherheitsrichtlinien

Verpflichtende Bestellung eines ISB

Ein ISB ist verpflichtend für:

- **KRITIS-Unternehmen** (IT-Sicherheitsgesetz)
- **Behörden** (BSI-Vorgaben)
- Organisationen mit ISO-27001-Zertifizierung

In anderen Unternehmen ist ein ISB Best Practice, aber nicht gesetzlich vorgeschrieben.

BDSG – Bundesdatenschutzgesetz

Das BDSG ergänzt die DSGVO und regelt nationale Besonderheiten. Es gilt für öffentliche Stellen und Unternehmen in Deutschland.

Wichtige Inhalte des BDSG

- **§ 26 BDSG** – Datenverarbeitung im Beschäftigungskontext
- **§ 38 BDSG** – Pflicht zur Bestellung eines Datenschutzbeauftragten
- **§§ 39–40 BDSG** – Aufgaben & Stellung des DSB
- **§ 41 BDSG** – Aufsichtsbehörden
- **§ 42 BDSG** – Strafvorschriften (z. B. unbefugte Datenverarbeitung)

Beispiele für Technische und Organisatorische Maßnahmen (TOMs)

Nach Art. 32 DSGVO müssen Unternehmen geeignete TOMs umsetzen. Beispiele:

Technische Maßnahmen

- Verschlüsselung (TLS, E-Mail, Festplatten)
- Zugriffskontrolle (MFA, Rollenmodelle)
- Firewall, VPN, IDS/IPS
- Backup & Restore-Tests
- Patch-Management
- Protokollierung & Monitoring
- Netzwerksegmentierung

Organisatorische Maßnahmen

- Schulungen & Sensibilisierung
- Datenschutz- und Sicherheitsrichtlinien
- Verzeichnis der Verarbeitungstätigkeiten (VVT)
- Notfallkonzept / Incident Response

- Clean-Desk-Policy
- Regelungen zur Auftragsverarbeitung
- Regelmäßige Audits